

S17 Semantic Traceability Demonstration (MITRE → Clinical Risk Mapping)

Purpose

This supplementary section demonstrates how a Cyber Threat Intelligence (CTI) artefact derived from the MITRE ATT&CK framework is linked to higher-level clinical risk constructs through the ontology-driven semantic enrichment layer of HIMS-CDI. The example specifically addresses the Semantic-Pragmatic Misalignment failure mode identified in the manuscript.

Example Scenario

MITRE Technique

T1566.001 — Phishing: Spearphishing Attachment

Step 1 – CTI Ingestion

A threat intelligence report indicates that a known Advanced Persistent Threat (APT) group is distributing spearphishing emails containing malicious attachments targeting NHS procurement personnel.

Step 2 – Ontology-Based Enrichment

The HIMS-CDI semantic mapper transforms MITRE ATT&CK techniques into clinically relevant cybersecurity risk constructs using a custom healthcare cybersecurity ontology that extends STIX 2.1 with medical-device impact semantics.

Mapping Relationships

MITRE Technique	Mapped Clinical Risk Construct	Relationship
T1566.001 (Spearphishing)	credential_theft	caused_by
T1566.001	initial_access	achieves
T1566.001 → T1203 (Exploitation for Client Execution)	malware_execution	potential_next_step

Step 3 – Clinical Risk Impact

The enriched semantic constructs activate the following clinical risk rule:

If credential_theft AND initial_access are detected, then Clinical Impact Score = Severe (4/5).

The following clinical assets are consequently identified as potentially at risk:

- Electronic Patient Record (EPR) system
- Picture Archiving and Communication System (PACS)
- Infusion pump management server

Step 4 – Evidence Traceability

The semantic mapping process and subsequent rule activation are recorded in the Evidence Traceability Package (ETP), thereby establishing a fully auditable chain of evidence linking the original MITRE ATT&CK technique to the derived clinical risk determination.

Mapping File

The complete mapping set comprising 47 healthcare-filtered MITRE ATT&CK techniques and their corresponding clinical risk constructs is available within the repository:

`/ontology/mitre_to_clinical_risk.json`

Conclusion

This example demonstrates that HIMS-CDI can bridge the semantic gap between low-level CTI artefacts and high-level clinical risk semantics. Consequently, the framework enables cybersecurity risk assessment processes that are semantically coherent, operationally meaningful, and fully auditable.